zer0Track

An AI agent that checks parcel handoff evidence and recommends whether a delivery is ready to accept or needs review.

Track: Secure Logistics & Digital Trust — Handoff Trust Verifier | **Event:** GDEX x ANON x UTAR Agentic AI Cybersecurity Hackathon 2026

Team: Raja, Win, Nour, Bhone, Kogu

1. Problem and Users

A parcel scan, photo, or transfer code can be incomplete or inconsistent evidence of a handoff. zer0Track checks whether the parcel, authorised parties, and location agree before recommending acceptance, verification, or escalation. The prototype models these risks with synthetic records; it does not assess GDEX's production security or claim any courier relies on a single signal as proof.

A DOJ release (29 Sep 2026) describes two men convicted of using legitimate trucking companies to win shipping contracts then never delivering the loads (≥US$2M lost) [1]. A 2026 USPS OIG audit found 358 packages improperly scanned at a Norfolk unit, 306 (85.5%) marked "Delivered" despite not reaching the address [2]. Neither establishes a shared root cause or proves fraud — they motivate our synthetic scenarios only.

In Malaysia: Postal Forum (MCMC-designated self-regulator) called courier-impersonation scams "an organised threat" (Jun 2026) [3]; GDEX's own Facebook page has separately warned customers against fraudsters impersonating GDEX — confirmation, from the courier itself, that its brand is an active target [4].

Users: GDEX delivery-hub supervisors and depot dispatchers handling handoff discrepancies — zer0Track is a triage aid, not a replacement for judgment. **Impact (to be measured, not yet proven):** fewer unsupported "delivered" acceptances, faster triage.

---

2. Inputs and Trusted Data

Synthetic, EPCIS-inspired JSON events and lookup records: parcel/handoff IDs, timestamps, handler ID, location (with accuracy/source); transfer-code status (issued/expiry/consumed); manifest and authorisation records (handler, custodian, authorised receiver/delegate, checkpoint); handler-history; optional photo/signed-receipt metadata as supporting context only (not authenticated).

An authenticated account must match the assigned handler/custodian; receiver authority comes from trusted records, never claims in incoming notes. Verification contacts are pre-registered. Raw TAC/OTP secrets never enter prompts or audit displays. **Missing evidence is recorded as UNKNOWN, never a pass.**

---

3. Agent Workflow and Policy

1. **Validate the case** against the manifest (event, transfer code, timestamps).
2. **Run three mandatory checks**, each PASS/FAIL/UNKNOWN: **(a) Parcel/code integrity** — scan matches manifest, code valid and unreplayed; **(b) Identity/authority** — handler, custodian, authorised receiver/delegate; **(c) Location** — fresh evidence consistent with the permitted point, type, accuracy.
3. **Investigate uncertainty.** Timing and handler history are supporting context only. If a mandatory check is UNKNOWN or conflicting, the system selects one allowlisted read-only lookup via a fixed, deterministic mapping — never an LLM choice (delegation, checkpoint, custody history). Tool failure/timeout/exhausted budget → operator review.
4. **Explain**: passed/failed/unknown checks, evidence IDs, unresolved questions, recommended action — a concise log, not a confidence score.
5. **Policy enforces the outcome**, independently of the LLM, revalidating all mandatory checks before acceptance. Tool selection is deterministic and fixed in code; the LLM never selects lookups or influences which tool runs

Parcel/code	Identity	Location	Recommendation
PASS	PASS	PASS	Accept (policy revalidates first)
PASS	PASS	FAIL/UNKNOWN	Request verification; pending if unresolved
PASS	UNKNOWN	Any	Hold — supervisor approval required
PASS	FAIL	Any	Hold — supervisor approval required
FAIL (e.g. replay)	Any	Any	Escalate — supervisor approval required
Any	Any	Tool failure/timeout	Operator review; never auto-accept

Investigation policy (cuts false alerts): condo/gated-community drop-offs routinely happen at a guardhouse, not the unit door, and ride-hailing/courier delays (Bolt, inDrive) shift timing without indicating fraud. A named, versioned policy defines which UNKNOWN/conflicting results trigger a lookup vs. resolve automatically against known-legitimate patterns (e.g. a registered guardhouse). Tuning this policy — not the mandatory checks — is how we trade off detection against false alerts (Section 6). **Architecture:** Streamlit → FastAPI/Pydantic → deterministic checks → allowlisted read-only deterministic lookups → independent policy/approval service → SQLite + hash-linked audit log. Each case renders as an **investigation timeline** (checks, tools, evidence, decision, in order) so an operator can see exactly what was examined and why. The model cannot register keys, edit permissions, complete a delivery, approve a hold, or bypass policy.

---

4. Safeguards

- **Transfer codes:** bound to parcel/transaction/receiver; checked against server time; acceptance atomically consumes a valid code and changes custody state (prevents simultaneous reuse); repeated events/approvals handled idempotently.
- **Prompt injection:** incoming notes are untrusted input; fixed allowlist of read-only tools; arguments validated against schemas. Test cases: fake "approved by supervisor" text, an instruction to skip the location check, a forged system-style instruction in a photo caption. Risk reduced, not eliminated. **Human approval:** verification requests are non-disruptive; holds/escalations/rejections need an authenticated supervisor, who can disagree but not bypass mandatory checks. Approvals log evidence version, operator, decision, timestamp — stale approvals can't execute against a changed case. **Audit:** append-only, hash-linked log with a protected checkpoint; locations access-restricted, identifiers masked in the demo, retention defined.
- **OWASP Top 10 for LLM Applications** — mitigated by design: **LLM01** Prompt Injection, **LLM02** Sensitive Info Disclosure (no raw TAC/OTP in prompts/logs), **LLM05** Improper Output Handling (evidence rendered as plain text, never executed), **LLM06** Excessive Agency (LLM has no tool-selection or execution agency at all — advisory classification only), **LLM09** Misinformation (policy is deterministic, separate from LLM prose), **LLM10** Unbounded Consumption (exhausted call budget → operator review) [8].

---

5. Demo and Evaluation

Demo (one last-mile journey, three runs): (1) condo guardhouse scan → delegation lookup finds a valid delegate → resolved; (2) same scan, no authorisation → pending, supervisor may hold; (3) replayed transfer code → blocked regardless of any recommendation. Depot/warehouse are additional test cases; live SMS, photo forensics, and production integration are out of scope.

Evaluation: 20 labelled synthetic cases (expected outcomes set in advance) across scan-only baseline, fixed rules, and rules+LLM — isolating whether adaptive investigation adds value beyond rules alone. We additionally run 2–3 investigation-policy variants (stricter/looser triggers) to show the detection-vs-false-alert tradeoff rather than one fixed setting. Reported: invalid-proof detection, false-alert rate, unsupported acceptances, unresolved cases, tool calls, time-to-recommendation — with counts and misses, not extrapolated to production. A **miss** = recommendation differs from the pre-set expected outcome; a **false alert** = a legitimate case flagged for verification/hold/escalation.

---

6. Limitations

A stolen-but-unused OTP can pass; spoofed coordinates can look consistent; collusion may defeat checks — the prototype cannot guarantee detecting phishing or all spoofing. GPS error, weak signal, or ordinary ride-hailing delay can cause false mismatches without meaning fraud — an alert requests verification, it never accuses. Photos/signatures support evidence integrity but don't prove physical possession. Location data raises PDPA considerations; masking alone isn't compliance. Scalability/latency are untested; there's no real-world pilot. The system depends on operators acting on recommendations — alert fatigue or rubber-stamping can weaken review.

---

7. Team Roles

Name	Role	Responsibility
Bhone	Backend/policy	API, validation, checks, policy table, audit logging
Kogu	Agent/security	Investigator, tool allowlist, arg validation, injection tests
Raja	Data/evaluation	Synthetic cases, baseline/rules/LLM comparison, policy-variant testing, metrics
Nour	Frontend/dashboard/demo	Streamlit dashboard, investigation timeline view; builds and rehearses the 3-run demo on top of it
Win	Integration / Pitch & Proposal	Integrates all parts into one working end-to-end flow; assembles the written proposal and pitch deck.

Live pitch presenting is shared — any one or two members present, not tied to a fixed role.

References

[1] DOJ, "Two Indian Nationals Found Guilty..." (29 Sep 2026) — justice.gov/usao-cdca

[2] USPS OIG, Report 26-044-1-R26, Norfolk S&DC (9 Apr 2026) — uspsoig.gov

[3] Bernama, "Postal Forum Urges Vigilance..." (23 Jun 2026) — bernama.com

[4] GD Express Official Facebook, "SCAM ALERT" — facebook.com/GDEXOfficialPage

[5] NIST SP 800-63B-4, *Digital Identity Guidelines* (2025) — pages.nist.gov

[6] JPDP Malaysia, *Principles of Personal Data Protection* — pdp.gov.my

[7] OWASP, *LLM01: Prompt Injection* (2025) — genai.owasp.org

[8] OWASP, *Top 10 for LLM Applications* (2025) — genai.owasp.org